

PARA O ALTO E AVANTE

CICLO DE VIDA DO INCIDENTE



12

LISTA DE FIGURAS

Figura 1 – Processo de resolução de incidentes de segurança	4
Figura 2 – Ciclo de resolução de incidentes.....	6



SUMÁRIO

1 CICLO DE VIDA DO INCIDENTE	4
1.1 Introdução	4
2 CICLO DE VIDA DO INCIDENTE: ATIVIDADES DO PROCESSO	6
2.1 Etapa 1: planejamento do processo	6
2.2 Etapa 2: detecção e comunicação	7
2.3 Etapa 3: avaliação e decisão.....	8
2.4 Etapa 4: resposta ao incidente de segurança	8
2.5 Etapa 5: lições aprendidas	9
3 PROPÓSITOS DE CONHECER O CICLO DE VIDA DO INCIDENTE	10
CONCLUSÃO	10
REFERÊNCIAS	12

1 CICLO DE VIDA DO INCIDENTE

1.1 Introdução

O tratamento de um incidente de segurança pressupõe uma preparação, um planejamento prévio e detalhado dos cenários possíveis e uma definição de linhas de ação em cada um desses cenários. É muito importante o conhecimento sobre em que fase estão as tratativas para solucionar o incidente de segurança.

Por se tratar de algo muito dinâmico, esse planejamento deve ser revisado, ampliado e discutido, sempre que possível. O aprendizado contínuo, aliado à experiência colhida por outras empresas ou equipes, reforça a probabilidade de sucesso no gerenciamento de um incidente de segurança da informação.

E, se tratando de um processo **cíclico**, que inter-relaciona os processos de detecção, análise, triagem e resposta, observa-se uma retroalimentação, de modo que a conclusão da etapa de resolução definitiva do problema dá origem a discussões e aprendizados que gerarão mais conhecimento e capacidade de enfrentamento, os quais devem servir de subsídio para eventos futuros.

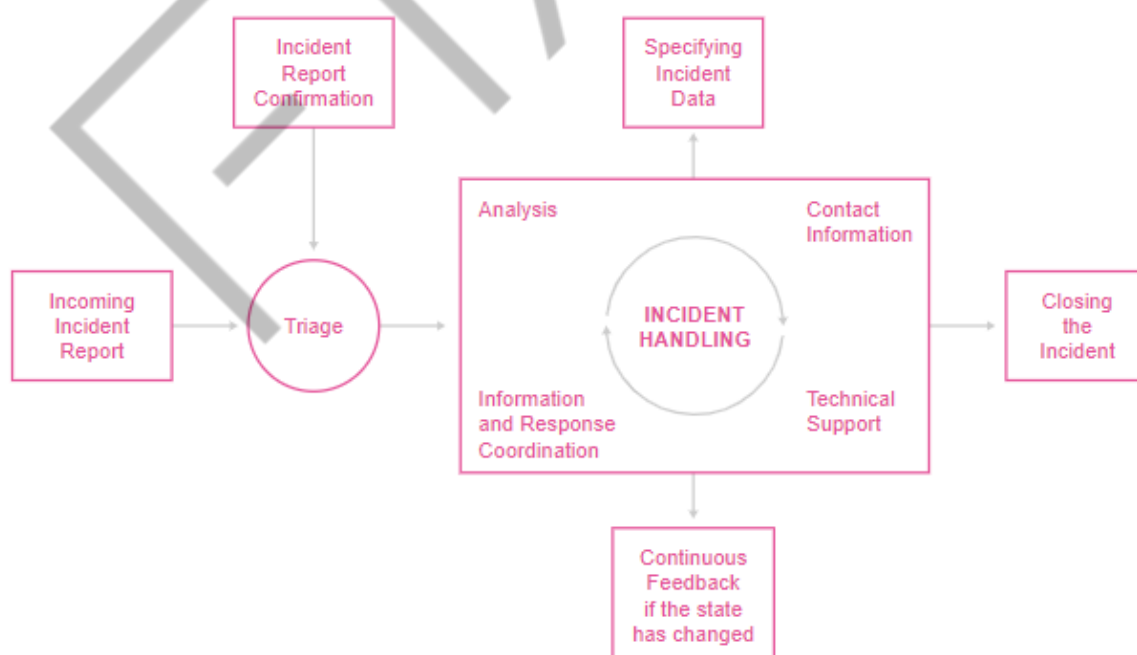


Figura 1 – Processo de resolução de incidentes de segurança
Fonte: ENISA (2010)

Neste capítulo, veremos um pouco mais a fundo o **ciclo de vida do incidente** e como as atividades de cada etapa se tornam importantes no contexto em que são utilizadas. Perceba que não há um guia definitivo para a resolução de incidentes de segurança, mas sim uma ferramenta em constante evolução, cooperativa e participativa, que facilita e orienta os trabalhos quando algo inesperado acontece e desencadeia as referidas etapas.

Importante: Evento e Incidente são conceitos que precisam ser diferenciados. **Evento** é qualquer ocorrência visível na rede ou em sistemas no ambiente organizacional. **Incidente** é um evento de segurança da informação que, após análise e verificação, indica uma possível falha ou comprometimento de segurança.

Vale salientar que existem diversos órgãos que disponibilizam modelos de referência, como o **ITIL** (*IT Infrastructure Library*), que auxiliam na confecção e ajuste dos processos de acordo com a necessidade específica de cada empresa.

Existem, inclusive, normas específicas sobre o tema, como a **ISO 27035**, manual detalhado para a gestão de incidentes de segurança da informação, que abordam aspectos relevantes para aqueles que adotam as boas práticas de segurança da informação, desde guias para declaração de uma política de gestão de incidentes até a divisão das responsabilidades envolvidas. A *International Organization for Standardization* (ISO) é uma organização internacional que padroniza e promove a normalização de produtos e serviços.

Saiba mais: Vale a pena dar uma olhada no *Guia de boas práticas para gerenciamento de incidentes de segurança da informação*, da ENISA (*European Union Agency for Cybersecurity* – Agência da União Europeia para Cibersegurança). O material, em formato PDF, pode ser baixado pelo link a seguir:

<<https://www.enisa.europa.eu/publications/good-practice-guide-for-incident-management>>.

Além de muito detalhado, o guia possui muitos fluxogramas que podem servir de referência para a elaboração de projetos específicos de acordo com a necessidade.

2 CICLO DE VIDA DO INCIDENTE: ATIVIDADES DO PROCESSO

O processo de tratamento de um incidente é definido como “qualquer evento adverso, confirmado ou sob suspeita” e envolve algumas etapas. Veremos a seguir, mais detalhadamente, cada uma delas e como isso constitui o chamado ciclo de vida do incidente.

Importante: Qualquer semelhança com as práticas sugeridas pelo “processo de gestão de problemas da ITIL” não é mera coincidência: as boas práticas em gestão de incidentes de segurança da informação possuem semelhanças com os processos de gerenciamento de incidentes e problemas da ITIL.

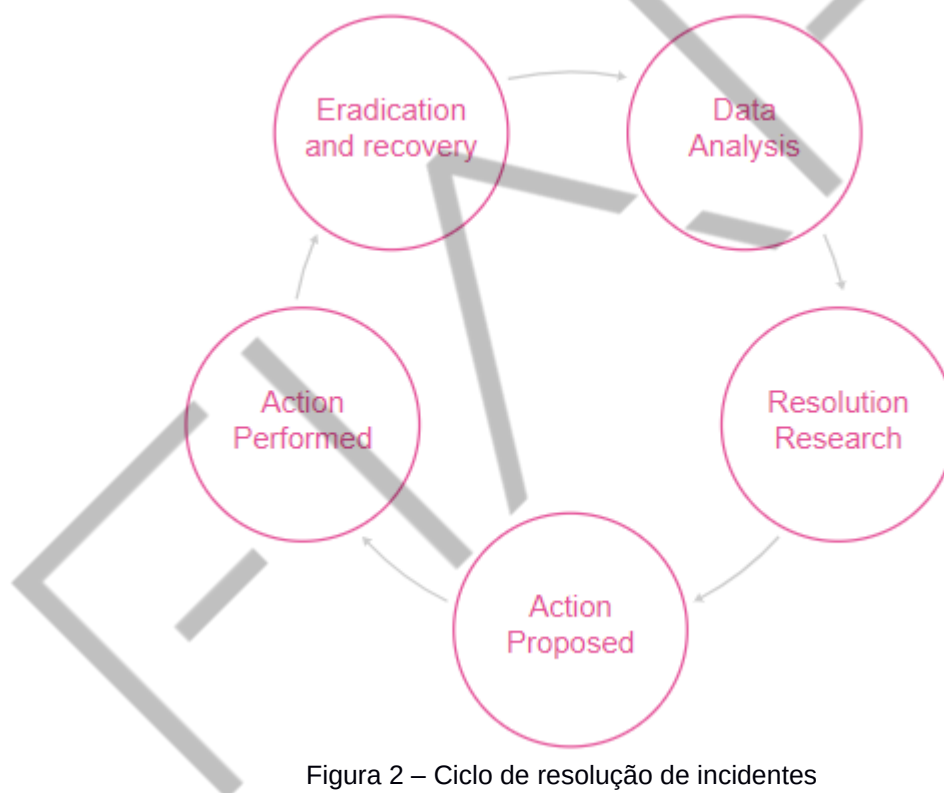


Figura 2 – Ciclo de resolução de incidentes
Fonte: ENISA (2010)

2.1 Etapa 1: planejamento do processo

Essa fase é essencial para o bom andamento das fases posteriores. É aqui que são definidas e planejadas as ações que serão adotadas nos diversos cenários enfrentados.

Cuidar de incidentes cotidianos já não é uma tarefa simples. Erros em sistemas operacionais e aplicações e problemas em terminais de usuários, por exemplo,

demandam cuidados e treinamento, apesar de mais corriqueiros. Quando tratamos de incidentes de segurança da informação, então, enfrentamos problemas e tarefas muito mais complexas e menos corriqueiras. Por isso, há a necessidade de preparação e planejamento, para que a resposta seja eficiente. Isso envolve alguns “instrumentos básicos” que se mostram muito necessários:

- Elaboração de uma política de gestão de incidentes de segurança da informação e uma lista de políticas de gestão de risco atualizadas.
- Elaboração de um fluxograma de incidentes de segurança da informação.
- Criação e estabelecimento de uma equipe de resposta a incidentes.
- Estabelecimento de uma equipe de suporte técnico especializada, bem capacitada e treinada.
- Adoção de ferramentas de testes e monitoramento e também de ferramentas para registro dos incidentes e eventos.

Esses instrumentos básicos podem (e devem) ser aprimorados constantemente, de maneira personalizada, pois cada cenário é único e as necessidades mudam de forma constante. Portanto, qualquer instrumento citado pode ser ampliado ou mesmo alterado, já que a receita ideal não existe de modo genérico, e sim de acordo com as diferentes realidades das empresas e dos órgãos.

Vale ressaltar, ainda, que é essencial:

- O **comprometimento da alta direção**, e não apenas das equipes envolvidas diretamente;
- A **conscientização** das equipes no que diz respeito à **sensibilidade** do tema, das etapas e dos procedimentos.

2.2 Etapa 2: detecção e comunicação

Essa etapa envolve a utilização de Ferramentas de Detecção e de Coleta de Informações, bem como a elaboração de relatórios sobre ocorrências e incidentes de segurança da informação, explorações de vulnerabilidades até então desconhecidas e os incidentes propriamente ditos.

É nessa etapa que são detectados os incidentes, as vulnerabilidades e as ocorrências e são gerados os relatórios que nortearão as etapas seguintes.

2.3 Etapa 3: avaliação e decisão

Essa fase, como o próprio nome já diz, tem como objetivo avaliar, com base nas informações levantadas e relacionadas na etapa anterior, classificar o evento como incidente ou não e, utilizando como referências a Política de Gestão de Incidentes de Segurança e os demais instrumentos predefinidos (etapa 1), conduzir as atividades listadas a seguir:

- Classificar o evento/incidente;
- Avaliar a situação (com base na classificação);
- Identificar os serviços que foram afetados;
- Mensurar os impactos nos ativos (levar em consideração os critérios da confidencialidade, integridade e disponibilidade);
- Priorizar e escalonar o evento/incidente conforme a classificação;
- Reportar o evento/incidente às partes interessadas;
- Atribuir responsabilidades e fornecer procedimentos adequados a cada responsável;
- Armazenar evidências e provas sobre causas do evento/incidente, se for o caso (principalmente em situações de exploração e/ou ataque).

Essas subatividades serão relevantes para as etapas 4 e 5, conforme veremos a seguir.

2.4 Etapa 4: resposta ao incidente de segurança

Essa fase já pressupõe a classificação da ocorrência como incidente de segurança e tem, no seu escopo, algumas subatividades:

- Responder aos incidentes de segurança da informação;

- Realizar análise forense;
- Manter as partes envolvidas informadas sobre o andamento do tratamento do incidente de segurança;
- Continuar o recolhimento e o armazenamento de evidências e provas iniciados na etapa anterior;
- Conter, mitigar e eliminar o incidente de segurança da informação;
- Recuperar os serviços impactados pelo incidente.

É importante ressaltar a importância do recolhimento de provas durante as etapas, pois isso será significativo em futuras questões de cunho legal e/ou disciplinar.

2.5 Etapa 5: lições aprendidas

Essa é uma das etapas mais importantes. É nela que é garantida a manutenção e a continuidade da Gestão da Segurança da Informação de maneira mais adequada e executável possível. Envolve, principalmente:

- Identificar e listar as lições aprendidas;
- Definir e listar as oportunidades de melhoria para a segurança da informação;
- Constatar os conhecimentos adquiridos e adicioná-los à base de conhecimentos existente;
- Detectar os novos procedimentos adotados, que serão utilizados em eventos futuros pela equipe de resposta a incidentes;
- Verificar oportunidades de melhorias (em processos, controles, normas e técnicas), bem como tendências para a proteção da informação;
- Garantir que sejam aplicadas todas as melhorias identificadas e listadas nessa etapa, comunicando às partes sobre essa necessidade.

3 PROPÓSITOS DE CONHECER O CICLO DE VIDA DO INCIDENTE

Há muitos benefícios práticos relacionados ao fato de conhecer o ciclo de vida do incidente, como:

- Ter a certeza de não omitir atividades importantes nesse processo;
- Ter a convicção do melhoramento contínuo da eficácia dos serviços, identificando fases longas demais e encurtando-as sempre que possível e verificando aumentos injustificados na duração das atividades, agindo sempre que for considerado necessário.

Saiba mais: O ciclo de vida do incidente, conforme a ITIL, consiste nas seguintes fases:

Ocorrência – interrupção não planejada em um serviço.

Deteção – acontece após a ocorrência do evento.

Diagnóstico – identificação das características do incidente.

Reparação – reconfiguração dos ativos atacados.

Recuperação – restauração dos ativos com falha (ao último estado recuperável possível).

Restauração – restabelecer o fornecimento do serviço aos usuários.

Encerramento – verificar se o serviço está totalmente disponível.

Vale a pena visitar o site da AXELOS que, desde 2013, é proprietária da ITIL. Ela licencia organizações para utilizar a propriedade intelectual ITIL, credencia institutos de exames licenciados e gerencia atualizações. Mais informações disponíveis em: <<https://www.axelos.com/best-practice-solutions/itil>>.

CONCLUSÃO

Como pudemos perceber, é possível planejar o gerenciamento de incidentes de segurança de diversas formas, de acordo com as peculiaridades de cada empre-

sa e utilizando, para isso, diversas fontes de consulta e orientações de órgãos de padronização e controle.

Entender o ciclo de vida de um incidente permite não apenas saber em que ponto da resolução as equipes estão, mas também serve de norteador para o processo como um todo. A virtude desse ciclo reside no fator educacional que ele carrega, sendo uma poderosa ferramenta no controle e na mitigação de danos. Mais que isso, esse ciclo fortalece a equipe e demonstra, na prática, como a cooperação influencia no processo de aprendizagem coletiva.

EMANIP

REFERÊNCIAS

CERT.br. **Cartilha de Segurança para Internet**. 2002. Disponível em: <<http://www.cartilha.cert.br>>. Acesso em: 13 jun. 2024.

CSIRT UFPA. **Pergunta frequentes**. 2018. Disponível em: <<https://ufla.br/acessoainformacao/destaques/perguntas-frequentes222>>. Acesso em: 13 jun. 2024.

ENISA. **Good Practice Guide for Incident Management**. 2010 Disponível em: <<https://www.enisa.europa.eu/publications/good-practice-guide-for-incident-management>>. Acesso em: 13 jun. 2024.

ITIL. **IT Service Management**. Disponível em: <<https://www.axelos.com/best-practice-solutions/itil>>. Acesso em: 13 jun. 2024.